

Module 03 — Scanning Networks (CEH v13)

Cours complet expliqué en français

Document pédagogique basé sur le PDF « CEHv13 - Module 03 - Scanning Networks » d'EC-Council (certification CEH, examen 312-50). Ce document reprend et explique tout le contenu du module, objectif par objectif.

Objectifs d'apprentissage

À la fin de ce module, vous serez capable de :

1. **Expliquer les concepts de scanning réseau** (network scanning concepts)
2. **Démontrer les techniques de scanning pour la découverte d'hôtes** (host discovery)
3. **Démontrer les techniques de scanning pour la découverte de ports et de services** (port and service discovery)
4. **Démontrer les techniques de découverte d'OS** (OS discovery)
5. **Démontrer les techniques de scanning au-delà des IDS et des firewalls**
6. **Expliquer les contre-mesures au scanning réseau**

Contexte : après l'identification de la cible et la reconnaissance initiale (Module 02 Footprinting), l'attaquant cherche un point d'entrée. Il doit d'abord déterminer si les systèmes cibles sont actifs ou inactifs pour réduire le temps de scanning. Le scanning n'est pas l'intrusion elle-même : c'est une forme étendue de reconnaissance qui apprend à l'attaquant des informations sur les OS, les services et les erreurs de configuration.

Objectif 01 — Concepts de scanning réseau

1.1 Vue d'ensemble du scanning réseau

Le scanning est le processus de collecte d'informations détaillées supplémentaires sur la cible en utilisant des techniques de reconnaissance complexes et agressives.

Le network scanning désigne un ensemble de procédures utilisées pour identifier les **hôtes**, les **ports** et les **services** dans un réseau. Il est aussi utilisé pour découvrir les machines actives et identifier l'OS de la machine cible.

Processus de scanning réseau : - L'attaquant envoie des **sondes TCP/IP** (TCP/IP probes) - Le réseau renvoie des **informations réseau** (network information) - L'attaquant crée un **profil de l'organisation cible**

Les attaquants utilisent des outils tels que **Nmap**, **Hping3**, **Metasploit** et **NetScanTools Pro** pour effectuer le scanning réseau.

But du scanning : découvrir des canaux de communication exploitables, sonder le plus de ports en écoute possible, et identifier ceux qui sont utiles. Dans la phase de scanning, l'attaquant cherche aussi à détecter des erreurs de configuration (configuration lapses) pour développer sa stratégie d'attaque.

1.2 Types de scanning

Type	Description
Port Scanning	Liste les ports ouverts et les services. Consiste à envoyer des messages en séquence (connexion ou sonde des ports TCP/UDP) pour déterminer si les services tournent ou sont en état d'écoute (listening). L'état d'écoute renseigne sur l'OS et l'application utilisés.

Type	Description
Network Scanning	Liste les hôtes actifs et les adresses IP. Procédure d'identification des hôtes actifs d'un réseau, soit pour les attaquer, soit pour évaluer la sécurité du réseau.
Vulnerability Scanning	Montre la présence de faiblesses connues. Un scanner de vulnérabilités comprend un moteur de scanning (scanning engine) et un catalogue (liste de fichiers connus vulnérables et d'exploits courants).

Métaphore des ports : un voleur cherche des points d'accès (portes, fenêtres) — les ports d'un système sont ses « portes et fenêtres ». Plus un système a de ports ouverts, plus il est vulnérable, mais un système avec moins de ports ouverts qu'un autre peut présenter un niveau de vulnérabilité plus élevé.

1.3 Objectifs du scanning réseau

- Découvrir les **hôtes actifs**, les **adresses IP** et les **ports ouverts** des hôtes actifs
- Découvrir l'**OS** et l'**architecture système** de la cible (fingerprinting)
- Découvrir les **services en cours d'exécution/écoute** sur la cible
- Identifier les **applications spécifiques** ou les versions d'un service particulier
- Identifier les **vulnérabilités** dans les systèmes réseau
- **Cartographier la topologie** du réseau (périphériques, routeurs, commutateurs, interconnexions)

1.4 Les flags de communication TCP

L'en-tête TCP contient des flags qui contrôlent la transmission des données. **Six flags de contrôle TCP** gèrent la connexion entre hôtes. Quatre d'entre eux (SYN, ACK, FIN, RST) gouvernent l'établissement, le maintien et la terminaison d'une connexion. Les deux autres (PSH et URG) donnent des instructions au système. Chaque flag a une taille de **1 bit** (section TCP Flags = 6 bits). Quand un flag est à « 1 », il est activé.

Flag	Rôle
SYN (Synchronize)	Notifie l'émission d'un nouveau numéro de séquence. Représente l'établissement d'une connexion (three-way handshake) entre deux hôtes.
ACK (Acknowledgement)	Confirme la réception d'une transmission et identifie le prochain numéro de séquence attendu.
PSH (Push)	À « 1 », indique que l'émetteur demande au destinataire de traiter les données immédiatement. Placé au début et à la fin du transfert de données et sur le dernier segment d'un fichier (évite les deadlocks de buffer).
URG (Urgent)	Ordonne au système de traiter les données dès que possible. À « 1 », le traitement des données urgentes est prioritaire.
FIN (Finish)	À « 1 », annonce qu'aucune autre transmission ne sera envoyée ; la connexion établie par SYN est terminée.
RST (Reset)	En cas d'erreur dans la connexion, ce flag est mis à « 1 » et la connexion est avortée. Les attaquants utilisent ce flag pour scanner les hôtes et identifier les ports ouverts.

À retenir : le SYN scanning concerne principalement trois flags : **SYN, ACK et RST**. Ces trois flags peuvent servir à recueillir des informations illégitimes des serveurs pendant l'énumération.

Format de l'en-tête TCP (champs) : Source Port, Destination Port, Sequence No, Acknowledgement No, Offset, Res, TCP Flags, Window, TCP Checksum, Urgent Pointer, Options (0-31 bits).

1.5 Communication TCP/IP

TCP est orienté connexion : il priorise l'établissement d'une connexion avant le transfert de données. Cette connexion est rendue possible par le **three-way handshake**.

Établissement d'une session TCP (three-way handshake) :

Étape	Émetteur	Paquet	Signification
1	Client (10.0.0.2:21)	SYN (SEQ #10)	« Je voudrais parler à Sheela sur le port 21, es-tu ouvert ? »
2	Serveur (10.0.0.3:21)	SYN+ACK (ACK #11, SEQ #142)	« D'accord, je suis ouvert sur le port 21 »
3	Client	ACK (ACK #143, SEQ #11)	« Merci Sheela » → connexion OPEN

La connexion continue jusqu'à ce que l'un émette un paquet **FIN** ou **RST** pour la fermer.

Terminaison d'une session TCP : 1. L'émetteur envoie un **FIN** (SEQ #50) : « J'ai terminé le transfert de données » 2. Le récepteur répond par un **ACK** (ACK #51, SEQ #170) : « J'ai reçu ta demande de terminaison » 3. Le récepteur envoie son propre **FIN** (SEQ #171) : « J'ai reçu toutes les données » 4. L'émetteur répond par un **ACK** (ACK #172, SEQ #51) : « Merci Sheela » → connexion terminée

TCP maintient des connexions **avec état (stateful)** pour tous les protocoles orientés connexion à travers Internet (comme une conversation téléphonique).

1.6 Outils de scanning

Les outils de scanning servent à identifier les hôtes actifs, les ports ouverts, les services en cours d'exécution, les informations de localisation, les informations NetBIOS et tous les ports ouverts TCP/IP et UDP.

Nmap (Network Mapper) — <https://nmap.org>

C'est le scanner de sécurité de référence pour l'exploration de réseau et le hacking. Il permet de découvrir hôtes, ports et services sur un réseau informatique, créant ainsi une « carte » du réseau. Il envoie des paquets spécialement conçus à la cible puis analyse les réponses.

- **Syntaxe** : `nmap <options> <adresse IP cible>`
- Utilise : scan de ports (TCP et UDP), détection d'OS, détection de versions, ping sweeps, etc.
- **Pour les administrateurs** : inventaire réseau, planification des mises à jour de services, surveillance de la disponibilité.
- **Pour les attaquants** : hôtes actifs, ports ouverts, services (nom d'application et version), type de filtres de paquets/firewalls, détails MAC, OS et versions.

Zenmap est l'interface graphique de Nmap. Exemple de commande : `nmap -p 1-65535 -T4 -A -v 10.10.1.11`.

Hping3 — <https://salsa.debian.org>

Outil de scanning réseau et de création de paquets orienté ligne de commande, pour le protocole TCP/IP. Il envoie des requêtes echo ICMP et supporte TCP, UDP, ICMP et raw-IP. Fonctions : audit de sécurité réseau, test de firewall, découverte MTU manuelle, traceroute avancé, fingerprinting OS distant, estimation du temps de fonctionnement (uptime), audit des piles TCP/IP, scanning idle, spoofing IP, transfert de fichiers encapsulés, canal de communication caché (covert channels), découverte de ports ouverts derrière les firewalls (firewalk-like).

- **Syntaxe** : `hping3 <options> <adresse IP cible>`

Les commandes Hping3 :

Commande	Fonction
<code>hping3 -1 10.0.0.25</code>	ICMP ping : envoie une requête echo ICMP (option <code>-1</code> ou <code>--icmp</code>), comme un ping
<code>hping3 -A 10.0.0.25 -p 80</code>	ACK scan sur le port 80 : sonde l'existence d'un firewall et ses règles (un filtre de paquets simple laisse passer l'ACK, un firewall stateful ne le laisse pas passer). Si hôte actif et port ouvert → réponse RST
<code>hping3 -2 10.0.0.25 -p 80</code>	UDP scan sur le port 80 : option <code>-2</code> ou <code>--udp</code> . Port fermé → message ICMP port unreachable ; port ouvert → pas de message
<code>hping3 192.168.1.103 -Q -p 139</code>	Collecte du numéro de séquence initial (ISN) : option <code>-Q</code> , collecte tous les numéros de séquence TCP générés par la cible
<code>hping3 -s 72.14.207.99 -p 80 --tcp-timestamp</code>	Firewalls et timestamps : active l'option TCP Timestamp (<code>--tcp-timestamp</code>) pour deviner la fréquence de mise à jour des timestamps et l'uptime de la cible
<code>hping3 -8 50-60 -S 10.0.0.25 -V</code>	SYN scan sur les ports 50-60 : option <code>-8</code> ou <code>--scan</code> (mode scan), <code>-S</code> = SYN scan
<code>hping3 -F -P -U 10.0.0.25 -p 80</code>	FIN, PUSH et URG scan sur le port 80 : options <code>-F</code> , <code>-P</code> , <code>-U</code> . Port ouvert → pas de réponse ; port fermé → réponse RST
<code>hping3 -1 10.0.1.x --rand-dest -I eth0</code>	Scan de tout le sous-réseau : ping ICMP aléatoire sur 10.0.1.0 à 10.0.1.255 via l'interface eth0
<code>hping3 -9 HTTP -I eth0</code>	Interception de tout le trafic contenant la signature HTTP : option <code>-9</code> = mode écoute, dumps les données après la signature
<code>hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood</code>	SYN flooding : attaque DoS avec adresses IP usurpées (option <code>-a</code> pour spoofing)

Metasploit — <https://www.metasploit.com>

Framework open-source qui fournit l'infrastructure, le contenu et les outils pour réaliser des tests d'intrusion et des audits de sécurité approfondis. Avantage majeur : **l'approche modulaire** (combinaison de n'importe quel exploit avec n'importe quel payload). Metasploit Pro permet de scanner ports/services, exploiter les vulnérabilités, pivoter dans le réseau, collecter des preuves et créer un rapport.

Modules de scan de ports : `auxiliary/scanner/portscan/ftpbounce`, `.../natpmp/natpmp_portscan`, `.../portscan/tcp`, `.../portscan/syn`, `.../portscan/xmas`, `.../portscan/ack`, `.../sap/sap_router_portscanner`, etc.

NetScanTools Pro — <https://www.netscantools.com>

Outil d'investigation permettant de dépanner, surveiller, découvrir et détecter les périphériques du réseau. Il liste les adresses IPv4/IPv6, noms d'hôtes, noms de domaine, adresses e-mail et URLs, automatiquement ou manuellement. Il combine de nombreux outils réseau classés par fonction (actifs, passifs, DNS, ordinateur local).

Autres outils de scanning : `sx` (github.com), `RustScan` (github.com), `MegaPing` (magnetosoft.com), `SolarWinds Engineer's Toolset` (solarwinds.com), `PRTG Network Monitor` (paessler.com).

Objectif 02 — Techniques de scanning pour la découverte d'hôtes

2.1 Découverte d'hôtes (Host Discovery)

Le scanning est le processus de collecte d'informations sur les systèmes qui sont « **vivants** » (alive) et répondent sur le réseau. **La découverte d'hôtes est la première tâche** du processus de scanning

réseau. Elle fournit l'état précis des systèmes, ce qui permet à l'attaquant d'éviter de scanner chaque port sur chaque système d'une liste d'adresses IP.

2.2 Les techniques de découverte d'hôtes

Technique	Option Nmap	Description
ARP Ping Scan	-PR	Envoie des paquets ARP pour découvrir tous les périphériques actifs de la plage IPv4, même cachés par des firewalls restrictifs. Si une réponse ARP est reçue → hôte actif. Technique la plus efficace et la plus précise. Gère automatiquement les requêtes ARP, retransmissions et timeouts.
UDP Ping Scan	-PU	Similaire au TCP ping, mais en UDP. Envoie des paquets UDP au port 40 125 (port par défaut, configurable via <code>DEFAULT_UDP_PROBE_PORT_SPEC</code> à la compilation). Réponse UDP → hôte actif ; host/network unreachable ou TTL exceeded → inactif. Avantage : détecte les systèmes derrière des firewalls qui filtrent strictement le TCP mais oublient l'UDP.
ICMP ECHO Ping Scan	-PE	Envoie des requêtes ICMP ECHO. Si l'hôte est vivant, il renvoie une réponse ICMP ECHO. Les machines UNIX/Linux et BSD répondent aux requêtes echo vers les adresses broadcast ; cela ne fonctionne pas sur Windows. Option <code>-P</code> pour le scan ICMP, <code>-L</code> pour augmenter les pings parallèles, <code>-T</code> pour le timeout.
ICMP ECHO Ping Sweep	-PE + plage	Envoie des requêtes ICMP ECHO à plusieurs hôtes (roll call). Technique la plus ancienne et la plus lente. Un paquet ping contient 64 octets (56 octets de données + 8 octets d'en-tête de protocole) . Les attaquants calculent les masques de sous-réseau puis créent un inventaire des systèmes actifs.
ICMP Timestamp Ping	-PP	Requête de timestamp pour obtenir l'heure courante de la cible. Efficace quand l'admin bloque l'ICMP ECHO traditionnel.
ICMP Address Mask Ping	-PM	Requête de masque d'adresse pour obtenir le masque de sous-réseau. Efficace quand l'admin bloque l'ICMP ECHO.
TCP SYN Ping	-PS	Initie le three-way handshake en envoyant un SYN TCP vide. La cible répond par ACK → l'attaquant confirme l'hôte actif puis envoie RST pour terminer la connexion. Port 80 par défaut (ex. <code>-PS22-25,80,113,1050,35000</code>). Avantages : scan parallèle sans timeout, aucun log créé (aucune connexion établie).
TCP ACK Ping	-PA	Envoie un paquet ACK TCP vide au port 80. Sans connexion préalable, la cible répond par un RST → hôte actif. Avantage : les firewalls bloquent surtout les SYN (technique la plus courante) ; la sonde ACK contourne facilement ces règles.
IP Protocol Ping	-P0	Envoie des paquets avec l'en-tête IP de n'importe quel numéro de protocole. Par défaut : ICMP (protocole 1), IGMP (protocole 2), IP-in-IP (protocole 4). Toute réponse → hôte en ligne.

Note : `-sn` est la commande Nmap pour **désactiver le scan de ports**. Comme Nmap utilise le ARP ping scan par défaut, utilisez `--disable-arp-ping` pour le désactiver et effectuer d'autres scans ping.

2.3 Découverte d'hôtes avec l'IA

Les attaquants peuvent automatiser la découverte d'hôtes avec ChatGPT ou d'autres outils d'IA générative (via `sgpt` par exemple) :

- « Scan the target network 10.10.1.0/24 for active hosts and place only the IP addresses into a file scan1.txt » → `nmap -sn 10.10.1.0/24 -oG - | awk '/Up/{print $2}' > scan1.txt`
- « Run a fast but comprehensive Nmap scan against scan1.txt with low verbosity and write the results to scan2.txt » → `nmap -T4 -iL scan1.txt -oN scan2.txt -v0`

- « Use Nmap to perform ICMP ECHO ping sweep on the target network 10.10.1.0/24 » → `nmap -sn -PE 10.10.1.0/24`

2.4 Outils de ping sweep

Les outils de ping sweep pingent toute une plage d'adresses IP pour identifier les systèmes actifs, en envoyant plusieurs requêtes ICMP ECHO simultanément.

Angry IP Scanner — <https://angryip.org> - Ping de chaque adresse IP pour vérifier si elle est vivante, puis résolution de nom d'hôte, détermination de l'adresse MAC, scan de ports, etc. - Détection de serveur web, plugins, enregistrement des résultats en CSV, TXT, XML ou listes IP-Port - **Multithread** : un thread de scan séparé est créé pour chaque adresse IP scannée

Autres outils de ping sweep : SolarWinds Engineer's Toolset, NetScanTools Pro, Colasoft Ping Tool (colasoft.com), Advanced IP Scanner (advanced-ip-scanner.com), OpUtils (manageengine.com).

Objectif 03 — Techniques de scanning pour la découverte de ports et de services

3.1 Découverte de ports et de services

L'étape suivante du processus de scanning consiste à vérifier les ports ouverts et les services sur les systèmes actifs. Les administrateurs l'utilisent pour gérer leurs réseaux ; les attaquants pour identifier les ports ouverts et les services, avec l'intention de compromettre le réseau. Parfois, les utilisateurs gardent involontairement des ports ouverts inutiles.

3.2 Table des ports courants et services (réservés)

Port/Protocole	Service	Description
7/tcp, udp	echo	Echo
9/tcp, udp	discard	Sink null
11/tcp	systat	Users
13/tcp, udp	daytime	Daytime
15/tcp, udp	netstat	Netstat
17/tcp, udp	qotd	Quote
19/tcp, udp	chargen	ttytst source
20/tcp	ftp-data	Transfert de données FTP
21/tcp	ftp	Commande FTP
22/tcp	ssh	Secure Shell
23/tcp	telnet	Telnet
25/tcp	smtp	Serveur e-mail (Email server)
37/tcp, udp	time	Serveur de temps
39/tcp, udp	rlp	Resource location
53/tcp, udp	domain	Serveur de noms de domaine
66/tcp, udp	sql*net	Oracle SQL*net
67/udp	bootps	Serveur bootp
68/udp	bootpc	Client bootp

Port/Protocole	Service	Description
69/udp	tftp	Trivial File Transfer
70/tcp	gopher	Serveur gopher
79/tcp	finger	Finger
80/tcp, udp	www-http	WWW
88/tcp, udp	kerberos	Kerberos
109/tcp	pop2	PostOffice V.2
110/tcp	pop3	PostOffice V.3
111/tcp, udp	sunrpc	RPC 4.0 portmapper
113/tcp, udp	auth/ident	Service d'authentification
119/tcp	nnntp	Usenet Network News Transfer
123/udp	ntp	Network Time Protocol
137/tcp, udp	netbios-ns	NetBIOS Name Service
138/tcp, udp	netbios-dgm	NetBIOS Datagram Service
139/tcp, udp	netbios-ssn	NetBIOS Session Service
143/tcp, udp	imap	Internet Message Access Protocol
161/tcp, udp	snmp	SNMP
162/tcp, udp	snmp-trap	SNMP Trap
194/tcp, udp	irc	Internet Relay Chat
443/tcp	https	HTTPS (standard bien connu, hors table)
445/tcp, udp	microsoft-ds	Microsoft DS
500/udp	isakmp	ISAKMP/IKE
512/tcp	exec	BSD rexecd
513/tcp	login	BSD rlogind
514/tcp	shell	BSD rshd
515/tcp, udp	printer	spooler BSD lpd
540/tcp, udp	uucp	uucpd BSD uucpd
635/udp	mount	NFS Mount Service
1080/tcp, udp	socks	Proxy Socks
1433/tcp, udp	ms-sql-s	Microsoft SQL Server
1434/tcp, udp	ms-sql-m	Microsoft SQL Monitor
1723/tcp, udp	pptp	PPTP
2049/tcp, udp	nfs	Network File System
5060/tcp, udp	sip	Session Initiation Protocol
6000-6063/tcp	x11	X Window System
6667/tcp	irc	Internet Relay Chat

3.3 Les techniques de scanning de ports

Les techniques de scanning de ports sont classées selon le protocole utilisé :

Scanning TCP (méthodes ouvertes) : - TCP Connect / Full-Open Scan (-sT) - Half-open Scan (-sS)

Scanning TCP (méthodes furtives — Inverse TCP Flag Scan) : - Xmas Scan (-sX) - FIN Scan (-sF) - NULL Scan (-sN) - Maimon Scan (-sM) - ACK Flag Probe Scan (-sA) - TTL-Based Scan - Window-Based Scan (-sW)

Scanning TCP tiers et spoofé : - IDLE/IP ID Header Scan (-sI)

Scanning UDP : - UDP Scan (-sU)

Scanning SCTP : - SCTP INIT Scan (-sY) - SCTP COOKIE/ECHO Scan (-sZ)

Scanning SSDP : SSDP et List Scan (-sL)

Scanning IPv6 : IPv6 Scan (-6)

TCP Connect / Full-Open Scan (-sT)

Une des formes de scan TCP les plus **fiables**. Le système d'exploitation appelle `connect()` pour tenter d'ouvrir une connexion vers chaque port d'intérêt. Si le port écoute, `connect()` réussit ; sinon, erreur « port not reachable ».

- Le scan TCP Connect **complète le three-way handshake** puis envoie un **RST** pour fermer la connexion.
- **Port ouvert** : SYN → SYN+ACK → ACK → RST
- **Port fermé** : SYN → RST
- Accélération possible grâce aux sockets non bloquants et parallèles.
- **Inconvénient** : facilement détectable et filtrable — les logs de la cible révèlent la connexion.
- **Avantage** : ne nécessite **pas de privilèges super-utilisateur**.

Stealth Scan / Half-Open Scan (-sS)

Le scan furtif réinitialise brutalement la connexion TCP entre client et serveur **avant la fin du three-way handshake**, laissant la connexion à moitié ouverte (half-open).

- Le client envoie un SYN au serveur sur le port approprié.
- **Port ouvert** : le serveur répond par un SYN/ACK.
- **Port fermé** : le serveur répond par un RST.
- Le client envoie alors un **RST** pour fermer l'initiation avant qu'une connexion ne soit établie.

Les attaquants utilisent le scan furtif pour **contourner les règles de firewall et les mécanismes de journalisation**, et se cacher sous l'apparence d'un trafic réseau normal. Ne crée aucun log de connexion complète.

Inverse TCP Flag Scan

L'attaquant envoie des paquets de sonde TCP avec un flag (FIN, URG, PSH) activé, ou sans flags.

- **Port ouvert** : aucune réponse de l'hôte
- **Port fermé** : réponse **RST/ACK** (selon RFC 793)

Configurations de flags utilisées : - **FIN probe** : flag FIN activé - **Xmas probe** : flags FIN + URG + PUSH activés - **NULL probe** : aucun flag - **SYN/ACK probe**

Important : les OS comme **Windows ignorent complètement la RFC 793** — aucune réponse RST/ACK sur un port fermé. Cette technique n'est efficace qu'avec les **OS basés sur UNIX** (pile BSD).

Noms selon les flags : aucun flag = **NULL scan** ; seulement FIN = **FIN scan** ; FIN+URG+PSH = **Xmas scan**.

Avantages : évite beaucoup d'IDS et de systèmes de journalisation, très furtif. **Inconvénients :** nécessite un accès brut aux sockets réseau et des privilèges super-utilisateur ; peu efficace contre les hôtes Windows.

Xmas Scan (-sX)

Type de scan TCP inverse avec les flags **FIN, URG et PUSH** activés (pattern URG-PSH-FIN).

- **Port ouvert :** aucune réponse
- **Port fermé :** réponse RST

Il sert à scanner de grands réseaux, déterminer quel hôte est actif et quels services il offre. **Ne fonctionne que sur les systèmes conformes à la RFC 793** (pas sur les versions actuelles de Microsoft Windows). Il repose sur le code réseau BSD (UNIX uniquement).

Avantages : évite l'IDS et le three-way handshake TCP. **Inconvénient :** fonctionne uniquement sur la plateforme UNIX.

TCP Maimon Scan (-sM)

Très similaire aux scans NULL, FIN et Xmas, mais la sonde utilisée est **FIN/ACK**.

- **Aucune réponse** après plusieurs retransmissions → port **open/filtered**
- **RST** → port **closed**
- **ICMP unreachable error** (type 3, codes 1, 2, 3, 9, 10 ou 13) → port **filtered**

ACK Flag Probe Scan (-sA)

L'attaquant envoie des paquets TCP avec le flag ACK activé puis analyse les informations d'en-tête (**TTL** et **champ WINDOW**) des paquets RST reçus. Exploite les vulnérabilités de la pile TCP/IP dérivée de BSD — efficace seulement sur ces OS.

Catégories :

1. **TTL-Based ACK Flag Probe Scan :** envoie des milliers de sondes ACK puis analyse le champ TTL des RST reçus. - TTL du paquet RST **< 64** (boundary value) → **port ouvert** - Exemple : port 22 renvoie TTL 50 (< 64) → ouvert ; les autres ports renvoient TTL 80 → fermés.
2. **Window-Based ACK Flag Probe Scan (-sW) :** utilise la valeur du champ window des RST quand tous les ports renvoient le même TTL. - Valeur de window **non nulle** → **port ouvert** - Valeur de window **nulle** → port fermé - **Avantage :** contourne l'IDS dans la plupart des cas. - **Inconvénient :** extrêmement lent, ne fonctionne que sur les anciens OS avec des piles BSD vulnérables.

Vérification des systèmes de filtrage de la cible : - Sonde ACK avec un numéro de séquence aléatoire, **aucune réponse** → port **filtré** (firewall stateful présent) - Réponse **RST** → port non filtré (pas de firewall)

IDLE/IPID Header Scan (-sI)

Scan de ports TCP qui utilise une **adresse source usurpée** pour déterminer les services disponibles. Il offre un **scan totalement aveugle** et fonctionne en utilisant un hôte intermédiaire appelé « **zombie** ». Chaque paquet IP sur Internet possède un identifiant IP (**IPID**) unique, incrémenté d'un à chaque paquet envoyé. Sonder un IPID révèle le nombre de paquets envoyés depuis la dernière sonde.

Étapes : 1. **Choisir un zombie** et sonder son IPID actuel. Envoyer un SYN+ACK au zombie → il répond par un RST (il n'attend pas ce paquet) contenant l'IPID (ex. IPID=31337 = X). 2. **Envoyer un SYN au port cible en usurpant l'IP du zombie :** - **Port ouvert :** la cible envoie un SYN+ACK au zombie (IP usurpée). Le zombie ne l'attend pas → répond par un RST, et son IPID passe à **X+1** (31338). - **Port fermé :** la cible répond par un RST au zombie → le zombie reste inactif, IPID inchangé. 3. **Resonder le zombie :** envoyer un nouveau SYN+ACK → le zombie répond avec son IPID suivant. - IPID incrémenté de **2** depuis l'étape 1 (ex. 31339 = X+2) → **le port est ouvert** - IPID incrémenté de 1 → port fermé

UDP Scan (-sU)

Utilise le protocole UDP au lieu de TCP. Il n'y a **pas de three-way handshake** pour UDP.

- Envoyer un paquet UDP vers un port **sans application** → la pile IP renvoie un **ICMP port unreachable** → port **fermé**
- **Aucune réponse** → port **ouvert** ou **filtré**
- Le scan UDP doit implémenter des **retransmissions** car les paquets perdus sont interprétés comme ports ouverts. Il est **lent** car limité par le taux de messages d'erreur ICMP (RFC 1812, section 4.3.2.8).
- **UDP RECVFROM() et WRITE() scanning** : les utilisateurs non-root ne peuvent pas lire directement les erreurs port unreachable. Linux en informe indirectement : un second appel `write()` vers un port fermé échoue généralement (ECONNREFUSED). Outils : Netcat, Pluvial pscan.c.
- **Avantages** : moins de trafic, très efficace sur Windows (pas de rate limiting ICMP).
- **Inconvénients** : fournit seulement des informations de port (compléter avec `-sV` ou `-0`) ; requiert des privilèges ; beaucoup de réseaux ont un trafic TCP massif réduisant l'efficacité.

SCTP INIT Scan (-sY)

SCTP (Stream Control Transport Protocol) est un protocole de transport orienté message et fiable, alternative à TCP et UDP. Il est utilisé pour le **multi-homing** et le **multi-streaming** (applications VoIP, IP telephony, SS7/SIGTRAN).

L'association SCTP utilise un four-way handshake : INIT → INIT-ACK → COOKIE-ECHO → COOKIE-ACK.

- Envoyer un chunk **INIT** à la cible :
- Port en écoute → chunk **INIT+ACK** → port **ouvert**
- Port fermé → chunk **ABORT** → port **fermé**
- Aucune réponse après plusieurs retransmissions, ou ICMP unreachable (type 3, codes 0, 1, 2, 3, 9, 10 ou 13) → port **filtré**
- Similaire au SYN scan TCP (rapide, furtif, connexion half-open).
- **Avantage** : différencie clairement les ports ouverts, fermés et filtrés.

SCTP COOKIE ECHO Scan (-sZ)

Scan plus avancé : l'attaquant envoie un chunk **COOKIE ECHO** à la cible.

- **Port ouvert** : la cible ignore silencieusement les paquets → aucune réponse
- **Port fermé** : réponse **ABORT**
- Le COOKIE ECHO n'est pas bloqué par les règles des firewalls non-stateful (contrairement à l'INIT scan). Seul un IDS avancé peut le détecter.
- **Avantage** : scan moins visible que l'INIT scan.
- **Inconvénient** : ne peut pas différencier clairement les ports ouverts et filtrés (affiche `open|filtered` dans les deux cas).

SSDP Scan et List Scan

SSDP Scan (Simple Service Discovery Protocol) : protocole réseau qui communique avec les machines en utilisant des adresses multicast routables IPv4 ou IPv6. Le service SSDP contrôle la communication pour la fonctionnalité **Universal Plug and Play (UPnP)**. La réponse inclut des informations sur la fonctionnalité UPnP. L'attaquant utilise le scan SSDP pour détecter les vulnérabilités UPnP permettant des **attaques buffer overflow ou DoS**. Outil : module Metasploit `auxiliary/scanner/upnp/ssdp_msearch` (port 1900/UDP).

List Scan (-sL) : la découverte des hôtes est indirecte — le scan génère et imprime une liste d'IP/noms **sans réellement pinger ou scanner les hôtes**. Toutes les adresses IP sont affichées comme « not

scanned » (0 hosts up). Une résolution DNS inverse est effectuée par défaut. - **Avantages** : bon sanity check ; détecte les adresses IP incorrectement définies.

IPv6 Scan (-6)

IPv6 augmente l'espace d'adressage de 32 bits à **128 bits**. La recherche classique est moins faisable car l'espace d'hôte est de **64 bits (2⁶⁴ adresses)** par sous-réseau. À un rythme d'une sonde par seconde, il faudrait environ **5 milliards d'années** pour vérifier une plage complète. Les attaquants récoltent des adresses IPv6 à partir du trafic réseau, des journaux, des en-têtes « Received from » des e-mails, etc. Une fois un hôte compromis, ils peuvent sonder l'adresse multicast locale « all hosts ». L'option Nmap est -6.

3.4 Découverte de versions de services (Service Version Discovery)

Chaque port est assigné à un service spécifique, et chaque service a sa propre version. Certaines versions des protocoles sont **insécures** et permettent à l'attaquant de compromettre la machine en exploitant la vulnérabilité. La détection de version de service (option -sV) examine les ports TCP et UDP : les sondes de la base **service-probes** de Nmap sont utilisées pour interroger les services et les expressions de correspondance reconnaissent et analysent les réponses.

3.5 Techniques de réduction du temps de scan Nmap

- **Omettre les tests non critiques** : éviter un scan intense si un minimum d'informations suffit ; limiter le nombre de ports ; sauter le scan de ports (-sn) si on vérifie seulement si les hôtes sont en ligne ; éviter les types de scan avancés (-sC , -sV , -O , --traceroute , -A) ; activer la résolution DNS seulement si nécessaire.
- **Optimiser les paramètres de timing** : option -T pour l'agressivité de timing (utile pour les réseaux très filtrés).
- **Séparer et optimiser les scans UDP** : scanner l'UDP séparément (exigences de performance et caractéristiques de timing différentes ; l'UDP est plus affecté par le rate-limiting ICMP).
- **Mettre à niveau Nmap** : correctifs, améliorations algorithmiques, ARP scanning local haute performance.
- **Exécuter des instances Nmap concurrentes** : diviser le scan en groupes et les exécuter simultanément.
- **Scanner depuis un emplacement réseau favorable** : exécuter Nmap du réseau local vers la cible (defense-in-depth) ; scan externe obligatoire pour les tests de firewall.
- **Augmenter la bande passante et le temps CPU** disponibles.
- **Mode verbeux -v** pour un retour plus rapide.

3.6 Scanning de ports avec l'IA

Exemples de prompts ChatGPT (via sgpt) : - « Use Nmap to find open ports on target IP 10.10.1.11 » → `nmap 10.10.1.11` - « Perform stealth scan on target IP 10.10.1.11 and display the results » → `nmap -sS 10.10.1.11` - « Perform an XMAS scan on target IP 10.10.1.11 » → `nmap -sX 10.10.1.11` - « Use Nmap to scan for open ports and services against a list of IP addresses in scan1.txt and copy only the port, service and version information to a new file called scan3.txt » → `nmap -sV -iL scan1.txt --open | awk '/scan report for/{ip=$NF} /^[0-9]+\./tcp/{print ip " : " $0}' > scan3.txt` - « Use Metasploit to discover open ports on the IP address 10.10.1.22 » → `msfconsole -q -x "use auxiliary/scanner/portscan/tcp; set RHOSTS 10.10.1.22; run; exit"`

Objectif 04 — Techniques de découverte d'OS

4.1 Découverte d'OS / Banner Grabbing (OS Fingerprinting)

Le **banner grabbing**, ou **fingerprinting OS**, est une méthode utilisée pour déterminer l'OS qui tourne sur un système cible distant. C'est important car beaucoup de vulnérabilités sont **spécifiques à un OS** : connaître l'OS permet de formuler une stratégie d'attaque ciblée.

Il existe **deux types de banner grabbing** :

1. Active Banner Grabbing : - Des paquets spécialement conçus sont envoyés à l'OS distant et les réponses sont notées - Les réponses sont comparées avec une **base de données** pour déterminer l'OS - Les réponses diffèrent selon les OS en raison des différences d'implémentation de la pile TCP/IP

Nmap utilise une série de **neuf tests** pour déterminer l'empreinte OS : - **Test 1** : paquet TCP avec flags **SYN et ECN-Echo** vers un port TCP ouvert - **Test 2** : paquet TCP **sans flag (NULL)** vers un port TCP ouvert - **Test 3** : paquet TCP avec flags **URG, PSH, SYN, FIN** vers un port TCP ouvert - **Test 4** : paquet TCP avec flag **ACK** vers un port TCP ouvert - **Test 5** : paquet TCP avec flag **SYN** vers un port TCP fermé - **Test 6** : paquet TCP avec flag **ACK** vers un port TCP fermé - **Test 7** : paquet TCP avec flags **URG, PSH, FIN** vers un port TCP fermé - **Test 8 (PU)** : paquet UDP vers un port UDP fermé pour extraire un message **ICMP port unreachable** - **Test 9 (TSeq)** : test d'échantillonnage de la séquence TCP — envoie six paquets TCP avec le flag SYN vers un port TCP ouvert pour trouver les motifs des numéros de séquence initiaux (ISN), des identifiants IP (IPID) et des timestamps TCP. - Catégories de motifs ISN : **64K traditionnel** (vieux UNIX), **incréments aléatoires** (Solaris, IRIX, FreeBSD, Digital UNIX, Cray), **vraiment aléatoire** (Linux 2.0., *OpenVMS, AIX*), *time-dependent** (Windows, ISN incrémenté d'un montant fixe).

2. Passive Banner Grabbing : capture les paquets de la cible via le **sniffing** pour étudier les signes révélateurs de l'OS (au lieu de scanner activement). - **Banner grabbing depuis les messages d'erreur** : type de serveur, type d'OS, outils SSL - **Sniffing du trafic réseau** : capture et analyse des paquets - **Banner grabbing depuis les extensions de page** : `.aspx` → serveur IIS et plateforme Windows

Les **quatre zones** qui déterminent typiquement l'OS : - **TTL (Time to Live)** des paquets - **Taille de la fenêtre (Window Size)** - **TOS (Type of Service)** - (et le bit **DF** — Don't Fragment)

Le fingerprinting passif n'est ni totalement précis ni limité à ces quatre signatures. Limites : les applications qui construisent leurs propres paquets (Nmap, Hunt, Nemesis) n'utilisent pas les signatures de l'OS ; un hôte distant peut ajuster TTL, window size, DF ou TOS.

4.2 Comment identifier l'OS du système cible

En analysant le **TTL (Time To Live)** et la **taille de la fenêtre TCP (window size)** dans l'en-tête IP du premier paquet d'une session TCP, on peut identifier l'OS. Le champ TTL détermine le temps maximal qu'un paquet peut rester dans un réseau ; la taille de fenêtre TCP détermine la longueur du paquet signalé. Ces valeurs varient selon les OS :

Système d'exploitation	Time To Live	Taille de fenêtre TCP
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65 535 octets à 1 Go
Routeurs Cisco	255	4128
Solaris	255	8760
AIX	255	16384

À retenir : TTL 64 → Linux/Unix ; TTL 128 → Windows ; TTL 255 → OS/routeurs réseau (OpenBSD, Cisco, Solaris, AIX).

4.3 Outils de découverte d'OS

Wireshark — <https://www.wireshark.org>

Capturez la réponse générée par la machine cible et observez les champs TTL et taille de fenêtre TCP du premier paquet TCP capturé. Comparez avec le tableau ci-dessus.

Nmap (option -O)

`nmap -O 10.10.1.11` fournit les détails d'OS de la cible : type de périphérique (general purpose), OS en cours d'exécution (Microsoft Windows 10), CPE, détails OS, distance réseau (1 hop).

UnicornsCan — <https://sourceforge.net>

`unicornsCan <adresse IP cible> -Iv` — l'OS est identifié en observant les valeurs TTL dans les résultats. TTL 128 → OS probablement Microsoft Windows.

Nmap Script Engine (NSE)

Le NSE automatise une grande variété de tâches réseau en permettant aux utilisateurs d'écrire et de partager des scripts. Le script `smb-os-discovery` collecte les informations d'OS de la machine cible via le protocole SMB. Activation générale : `-sC` ; scripts personnalisés : `--script`. Exemple : `nmap --script smb-os-discovery.nse 10.10.1.22` (renvoie OS Windows Server 2022 Standard, nom d'ordinateur, nom NetBIOS, nom de domaine, FQDN, heure système).

IPv6 Fingerprinting

Technique d'identification d'OS via IPv6. Différence avec IPv4 : IPv6 utilise plusieurs sondes avancées spécifiques à IPv6 et un moteur de détection OS séparé. Nmap envoie environ **18 sondes** dans l'ordre : - Séquences (S1-S6) - ICMPv6 echo (IE1, IE2) - Node Information Query (NI1) - Neighbor Solicitation (NS) - UDP (U1) - TCP explicit congestion notification (TECN) - TCP (T2-T7)

Syntaxe : `nmap -6 -O <cible>`

4.4 Découverte d'OS avec l'IA

- « Use TTL to identify the operating system running on the target IP address » → `ping -c 1 <IP>` et lecture du TTL (Linux/Unix = 64, Windows = 128)
- « Use Nmap script engine to perform OS discovery on the target IP addresses in scan1.txt » → `nmap -O -iL scan1.txt --script=default --script-args=newtargets -oN os_discovery_results.txt`

4.5 Créer et exécuter un script personnalisé pour automatiser le scanning avec l'IA

Prompt : « Develop a script which will automate network scanning efforts and find out live systems, open ports, running services, service versions, etc. on target IP range 10.10.1.0/24 »

```
#!/bin/bash
nmap -sP 10.10.1.0/24 -oG - | awk '/Up/{print $2}' > live_hosts.txt &&
nmap -iL live_hosts.txt -sV -oA scan_results &&
cat scan_results.nmap
```

Explication : - `nmap -sP 10.10.1.0/24 -oG -` : ping scan, format greppable (`-oG -`), piped vers `awk` pour extraire les adresses IP des hôtes actifs → `live_hosts.txt` - `nmap -iL live_hosts.txt -sV -oA scan_results` : scan des hôtes actifs pour les ports ouverts et les versions de services (`-sV`) ; `-oA` sauvegarde dans plusieurs formats (normal, XML, greppable) avec le préfixe `scan_results` - `cat scan_results.nmap` : affiche les résultats

Objectif 05 — Techniques de scanning au-delà de l'IDS et du firewall

Bien que les firewalls et les IDS puissent empêcher le trafic (paquets) malveillant d'entrer dans un réseau, les attaquants peuvent envoyer des paquets destinés à la cible qui échappent à l'IDS/firewall en mettant en œuvre les techniques suivantes :

Technique	Description
Packet Fragmentation	Scission d'un paquet de sonde en plusieurs petits paquets (fragments) lors de l'envoi. L'IDS et les firewalls traitent les fragments un par un (coûteux en CPU et ressources réseau) ; la configuration de la plupart des IDS leur fait sauter les paquets fragmentés pendant les scans de ports. À destination, les fragments sont réassemblés en un seul paquet.
Source Routing	Envoi d'un paquet vers la destination avec une route partiellement ou complètement spécifiée (sans routeurs configurés avec firewall/IDS). L'attaquant manipule le champ IP options pour que le paquet suive un chemin défini par l'attaquant. Deux types : loose et strict source routing.
Source Port Manipulation	Manipulation des numéros de port réels avec des numéros de port courants (HTTP, DNS, FTP) pour contourner certaines règles IDS/firewall. La plupart des administrateurs configurent le firewall en autorisant le trafic entrant depuis les well-known ports . Nmap : options <code>-g</code> ou <code>--source-port</code> (ex. <code>nmap -g 80 10.10.1.11</code>).
IP Address Decoy	Génération ou spécification manuelle d'adresses IP de leurre (decoys) pour contourner l'IDS/firewall. Il apparaît à la cible que les leurres et l'hôte scannent le réseau. Nmap : <code>-D RND:10 [target]</code> (nombre aléatoire de leurres) ou <code>-D decoy1,decoy2,decoy3,ME,... [target]</code> (liste manuelle ; ME positionne votre vraie IP). Les leurres sont générés dans les scans ping initiaux (ICMP, SYN, ACK) et pendant le scan de ports. Limites : inefficace si la cible emploie des mécanismes actifs (router path tracing, response dropping) ; trop de leurres ralentissent le scan et affectent la précision.
IP Address Spoofing	Changement de l'adresse IP source pour que l'attaque semble venir de quelqu'un d'autre. Quand la victime répond, la réponse va à l'adresse usurpée et non à l'adresse réelle de l'attaquant. Utilisé principalement pour les attaques DoS . Hping3 : <code>hping3 www.certifiedhacker.com -a 7.7.7.7</code> (option <code>-a</code>). Note : impossible de compléter le three-way handshake et d'ouvrir une connexion TCP réussie avec des adresses IP usurpées.
MAC Address Spoofing	Usurpation d'une adresse MAC avec celle d'un utilisateur légitime du réseau pour contourner les firewalls qui filtrent selon l'adresse MAC source. Nmap : option <code>--spoof-mac</code> avec : <code>0</code> (adresse MAC aléatoire), <code>[Vendor]</code> (ex. <code>Dell</code> , <code>3Com</code> — génère une MAC du fabricant), ou <code>[new MAC]</code> (adresse MAC manuelle, ex. <code>--spoof-mac 00:01:02:25:56:AE</code>).
Creating Custom Packets	Création et envoi de paquets personnalisés pour scanner la cible au-delà de l'IDS/firewall. Outils de packet crafting : Colasoft Packet Builder (colasoft.com), NetScanTools Pro (netscantools.com). Colasoft Packet Builder possède trois vues : Packet List, Decode Editor, Hex Editor. Il peut créer des paquets fragmentés, envoyer des flots de paquets et faire du flooding (DoS).
Randomizing Host Order	Scan des hôtes du réseau cible dans un ordre aléatoire pour scanner la cible au-delà du firewall. Nmap : <code>--randomize-hosts</code> — mélange chaque groupe de 16 384 hôtes avant de scanner avec des options de timing lent, rendant le scan moins notable.
Sending Bad Checksums	Envoi de paquets avec des checksums TCP/UDP invalides (bogus) à la cible pour éviter certaines règles de firewall. Les checksums TCP/UDP garantissent l'intégrité des données. Si une réponse est reçue, elle vient d'un IDS/firewall qui n'a pas vérifié le checksum. Nmap : option <code>--badsum</code> .
Proxy Servers	Application qui sert d'intermédiaire pour la connexion à d'autres ordinateurs.
Anonymizers	Serveur intermédiaire placé entre l'utilisateur final et un site web qui accède au site en son nom.

5.1 SYN/FIN Scanning Using IP Fragments

Ce n'est pas une nouvelle méthode de scan mais une modification des techniques précédentes, développée pour éviter les faux positifs dus à un dispositif de filtrage de paquets sur le système cible. L'en-tête TCP est scindé en plusieurs paquets pour contourner le filtre de paquets : le premier paquet doit contenir les ports source et destination (8 octets, 64 bits) ; les flags initialisés dans le paquet suivant permettent le réassemblage à destination. Nmap : option `-f` (ex. `nmap -sS -T4 -A -f -v 10.10.1.11`).

Risques : le réassemblage IP côté serveur peut produire des résultats imprévisibles ; certains hôtes peuvent échouer à analyser/réassembler les paquets fragmentés, entraînant des crashes, redémarrages ou dumps de monitoring. Certains firewalls bloquent les files de fragmentation IP (ex.

`CONFIG_IP_ALWAYS_DEFRAG` dans le noyau Linux), mais ce n'est pas largement implémenté (effets négatifs sur la performance).

5.2 Source Routing

Le datagramme IP contient le champ **IP options**, qui stocke les informations de source routing et la liste des adresses IP traversées. L'attaquant manipule le chemin d'adresse IP dans le champ options pour que le paquet suive un chemin défini par l'attaquant (sans routeurs configurés avec firewall/IDS) jusqu'à la destination, contournant ainsi firewalls et IDS.

5.3 Pourquoi les attaquants utilisent les serveurs proxy ?

- Cacher la source réelle d'un scan et contourner certaines restrictions IDS/firewall
- Cacher l'adresse IP source pour hacker sans conséquence juridique
- Masquer la source réelle de l'attaque en employant une fausse adresse source du proxy
- Accéder à distance aux intranets et ressources web normalement restreintes
- Interrompre toutes les requêtes d'un utilisateur et les transmettre à une destination tierce (les victimes ne peuvent identifier que l'adresse du proxy)
- **Chaîner plusieurs serveurs proxy** pour éviter la détection

Fonctionnement du proxy : le proxy reçoit la communication entre le client et l'application de destination. L'attaquant doit configurer les programmes client pour envoyer leurs requêtes au proxy au lieu de la destination finale. Dans les logs du serveur, l'adresse enregistrée est celle du proxy, pas celle de l'attaquant.

Proxy Chaining : 1. L'utilisateur demande une ressource à la destination 2. Un client proxy du système de l'utilisateur se connecte à un serveur proxy et lui transmet la requête 3. Le serveur proxy retire les informations d'identification de l'utilisateur et transmet la requête au serveur proxy suivant 4. Le processus est répété par tous les serveurs proxy de la chaîne 5. Enfin, la requête non chiffrée est transmise au serveur web

Plus le nombre de serveurs proxy utilisés est grand, plus l'anonymat de l'attaquant est grand.

Outils proxy : Proxy Switcher (proxyswitcher.com), CyberGhost VPN (cyberghostvpn.com), Burp Suite (portswigger.net), Tor (torproject.org), Hotspot Shield (hotspotshield.com), Proxifier (proxifier.com), IPRoyal Residential Proxy (iproyal.com).

5.4 Anonymisateurs

Un anonymizer est un serveur intermédiaire placé entre un utilisateur final et un site web. Il élimine toutes les informations d'identification (adresse IP) lors de la navigation, garantissant la confidentialité. Il chiffre les données transférées de l'ordinateur vers le FAI. La plupart peuvent anonymiser les services web (HTTP:), FTP (FTP:) et gopher (gopher:).

Pourquoi utiliser un anonymizer ? - Assurer la confidentialité : navigation intraçable -

Contourner la censure et les restrictions géographiques : accéder à des contenus jugés

inappropriés ou sensibles - **Protection contre les attaques en ligne** : protège contre le phishing en routant le trafic via son serveur DNS protégé - **Contourner le firewall de l'organisation**

Types d'anonymisateurs :

Type	Description	Avantage	Inconvénient
Networked Anonymizers	Transfèrent vos informations via un réseau d'ordinateurs connectés à Internet avant de les passer au site web	La complexité de la communication rend l'analyse du trafic compliquée	Tout réseau multi-nœuds comporte un risque de compromission de la confidentialité à chaque nœud
Single-Point Anonymizers	Transfèrent vos informations via un site web avant de les envoyer au site cible, puis renvoient les informations collectées	La communication à distance (arms-length) cache l'adresse IP	Offre moins de résistance à l'analyse sophistiquée du trafic

Outils anonymizers : Whonix (whonix.org — OS desktop de sécurité et confidentialité basé sur Debian, anonymat via le réseau **Tor**, exécuté dans des machines virtuelles), Psiphon (psiphon.ca), TunnelBear (tunnelbear.com), Invisible Internet Project / I2P (geti2p.net), Bright Data Proxy API (brightdata.com), AstrillVPN (astrill.com — contourne la censure et les blocages géographiques), Tails (tails.net — OS live sur clé USB/SD, cryptographie, anonymat Tor, **ne laisse aucune trace** sur l'ordinateur).

Objectif 06 — Contre-mesures au scanning réseau

Dans le hacking éthique, le pentester doit aussi adopter des **contre-mesures** contre les vulnérabilités déterminées. Connaître les failles de sécurité de son réseau est inutile sans mesures pour les protéger contre les vrais hackers.

6.1 Contre-mesures au ping sweep

- Configurer les firewalls pour **bloquer les requêtes ICMP echo entrantes** de sources inconnues ou non fiables
- Utiliser des **IDS et IPS**, comme **Snort** (snort.org), pour détecter et prévenir les tentatives de ping sweep
- Évaluer soigneusement le type de trafic **ICMP** traversant les réseaux d'entreprise
- **Terminer la connexion** avec tout hôte envoyant plus de 10 requêtes ICMP ECHO
- Utiliser une **DMZ** et n'autoriser que des commandes telles que ICMP ECHO_REPLY, HOST UNREACHABLE et TIME EXCEEDED dans la DMZ
- Limiter le trafic ICMP avec des **ACL** aux adresses IP spécifiques du FAI
- Implémenter le **rate limiting** pour les paquets ICMP
- **Segmenter le réseau** en plus petites zones isolées
- Utiliser des **plages d'adresses IP privées** pour les périphériques internes et implémenter le **NAT** à la frontière du réseau

6.2 Contre-mesures au port scanning

- Configurer les règles **firewall et IDS pour détecter et bloquer les sondes**
- **Exécuter des outils de scanning de ports** contre les hôtes du réseau pour déterminer si le firewall détecte correctement l'activité de scan
- **Filtrer tous les messages ICMP** (types ICMP entrants et messages sortants de type 3 unreachable) aux firewalls et routeurs
- Effectuer des **scans TCP et UDP** ainsi que des **sondes ICMP** sur l'espace d'adresses IP de l'organisation

- S'assurer que les mécanismes de **roulage et de filtrage** ne peuvent pas être contournés via un port source particulier ou des méthodes de source routing
- S'assurer que le **firmware du routeur, de l'IDS et du firewall** est mis à jour
- S'assurer que les règles **anti-scanning et anti-spoofing** sont correctement configurées
- Garder **aussi peu de ports ouverts que possible** et filtrer le reste. Utiliser un ensemble de règles personnalisé pour verrouiller le réseau et **filtrer les ports : 135-159, 256-258, 389, 445, 1080, 1745 et 3268**
- **Bloquer les services indésirables** tournant sur les ports et mettre à jour les versions de services
- S'assurer que les versions des services ne sont pas vulnérables
- Employer un **IPS** pour identifier les tentatives de scan de ports et **mettre sur liste noire** les adresses IP
- Implémenter le **port knocking** pour cacher les ports ouverts
- Utiliser le **NAT** pour cacher les adresses IP des systèmes internes
- Implémenter le **filtrage de sortie (egress filtering)** pour contrôler le trafic sortant
- Implémenter des **VLAN** pour isoler les différents types de trafic
- Utiliser des **serveurs proxy** pour bloquer les paquets fragmentés ou malformés
- Si un firewall commercial est utilisé : patché avec les dernières mises à jour, règles anti-spoofing correctement définies, services fast-mode inutilisables
- S'assurer que les **TCP wrappers** limitent l'accès au réseau en fonction des noms de domaine ou des adresses IP
- Transférer les scans de ports ouverts vers des **hôtes vides ou honeypots**

6.3 Contre-mesures au banner grabbing

Désactivation ou modification du banner : - Afficher de **faux bannières** pour tromper les attaquants - **Éteindre les services inutiles** sur l'hôte réseau pour limiter la divulgation d'informations - Utiliser des **outils de masquage de serveur** pour désactiver ou modifier les informations de bannière - Supprimer les **en-têtes HTTP et données de réponse inutiles** et camoufler le serveur en fournissant de fausses signatures ; éliminer les extensions de fichiers telles que `.asp` et `.aspx` (indiquent un serveur Microsoft) - Pour **Apache 2.x** avec le module `mod_headers` : utiliser une directive dans le fichier `httpd.conf` pour changer l'en-tête d'information de bannière et définir le serveur comme « New Server Name » ; alternativement, définir `ServerSignature off` dans `httpd.conf` - Désactiver les détails du **vendeur et de la version** dans les bannières - Modifier la valeur de `ServerTokens` de `Full` à `Prod` dans `httpd.conf` d'Apache pour empêcher la divulgation de la version du serveur - Modifier la valeur de `RemoveServerHeader` de `0` à `1` dans le fichier de configuration `Urlscan.ini` (C:\windows\system32\inetsrv\Urlscan) pour empêcher la divulgation de la version du serveur - Modifier la valeur de `AlternateServerName` (ex. `xyz` ou `myserver`) pour tromper les attaquants - **Désactiver les méthodes HTTP** telles que `CONNECT`, `PUT`, `DELETE` et `OPTIONS` sur les serveurs d'applications web - Supprimer l'en-tête **X-Powered-By** avec l'option `customHeaders` dans la section `<system.webServer>` du fichier `web.config`

Masquer les extensions de fichiers des pages web : - **Cacher les extensions de fichiers** pour masquer la technologie web - Remplacer les mappages d'applications tels que `.asp` par `.htm`, `.foo`, etc. - Les utilisateurs Apache peuvent utiliser les directives `mod_negotiation` - **Note :** il est préférable de ne pas utiliser d'extensions de fichiers du tout

Autres contre-mesures au banner grabbing : - Utiliser le **filtrage de paquets** pour bloquer ou restreindre l'accès aux ports qui pourraient révéler des informations de bannière - Utiliser des **IDS/IPS** pour surveiller et alerter sur les activités de scan - Remplacer les protocoles qui envoient des bannières en clair (`HTTP`, `FTP`, `Telnet`) par leurs homologues sécurisés (**`HTTPS`**, **`SFTP/FTPS`**, **`SSH`**) pour chiffrer la connexion et les informations de bannière

6.4 Techniques de détection du spoofing IP

1. Direct TTL Probes : envoyez un paquet (ping request) à l'hôte légitime et attendez la réponse. Le TTL de la réponse doit correspondre au TTL du paquet vérifié s'ils utilisent le même protocole. Valeurs TTL initiales courantes : TCP/UDP = **64 et 128** ; ICMP = **128 et 255**. Soustrayez le TTL de la réponse du TTL initial pour déterminer le nombre de sauts (hop count). Si le TTL de la réponse ne correspond pas → paquet usurpé. **Cette technique réussit quand l'attaquant est dans un sous-réseau différent de celui de la victime.** (Normal traffic from one host can contrast TTLs depending on traffic patterns.)

2. IP Identification Number (IPID) : l'IPID augmente de façon incrémentale à chaque paquet envoyé. Envoyez une sonde à l'adresse source du paquet suspect et observez l'IPID dans la réponse. Si les IPID ne sont pas proches en valeur du paquet vérifié → trafic usurpé. **Cette technique est fiable même si l'attaquant est dans le même sous-réseau.**

3. TCP Flow Control Method : le contrôle de flux TCP utilise le **principe de la fenêtre glissante (sliding window)**. Le champ window size représente la quantité maximale de données que le destinataire peut recevoir et que l'émetteur peut transmettre sans accusé de réception. L'émetteur doit arrêter d'envoyer quand la fenêtre est épuisée. Les attaquants envoyant des paquets TCP usurpés **ne recevront pas les SYN-ACK de la cible** et ne pourront donc pas répondre aux changements de taille de fenêtre de congestion. Si le trafic reçu continue après l'épuisement de la taille de fenêtre → les paquets sont probablement usurpés. Pour un contrôle de flux efficace et une détection précoce, la **taille de fenêtre initiale doit être très petite**. La plupart des attaques de spoofing se produisent pendant le handshake.

6.5 Contre-mesures au spoofing IP

- **Éviter les relations de confiance :** ne pas s'appuyer sur l'authentification basée sur IP ; implémenter une authentification par mot de passe en plus de l'authentification basée sur la relation de confiance
- **Utiliser des firewalls et mécanismes de filtrage :** filtrer tous les paquets entrants et sortants ; ACL pour bloquer les accès non autorisés
- **Utiliser des numéros de séquence initiaux aléatoires** pour prévenir les attaques de spoofing basées sur les numéros de séquence (la plupart des périphériques choisissent leurs ISN sur des compteurs temporisés → prévisibles)
- **Ingress Filtering :** empêche le trafic usurpé d'entrer sur Internet. Appliqué aux routeurs ; configurer et utiliser des ACL qui suppriment les paquets avec une adresse source en dehors de la plage définie
- **Egress Filtering :** bloque les paquets sortants avec une adresse source de l'extérieur (adresse locale invalide)
- **Utiliser le chiffrement (Encryption) :** chiffrer tout le trafic mis sur les supports de transmission. IPsec réduit considérablement le risque de spoofing IP (authentification des données, intégrité et confidentialité). TLS, SSH, HTTPS
- **Utiliser plusieurs firewalls** pour une protection multicouche (defense-in-depth)
- **SYN Flooding Countermeasures :** les contre-mesures contre le SYN flooding aident aussi à éviter les attaques de spoofing IP
- **Autres contre-mesures :** migrer vers IPv6 pendant le développement ; implémenter l'authentification par certificat numérique (certificats de domaine et à deux voies) ; utiliser un **VPN sécurisé** avec les services Internet publics ; utiliser des dispositifs d'atténuation spécifiques à l'application (ex. **Behemoth scrubbers**, environ 100 millions de paquets/s) ; implémenter la variation dynamique d'adresse IPv6 (générateur d'adresses aléatoire) ; configurer les routeurs pour envoyer des informations encodées sur les paquets fragmentés entrant dans le réseau ; configurer les routeurs pour vérifier les paquets par leurs signatures (digests) ; configurer les routeurs pour cacher les hôtes intranet via NAT ; configurer les commutateurs internes pour tableer les adresses statiques DHCP et filtrer le trafic usurpé ; utiliser des versions sécurisées des protocoles de communication (HTTPS, SFTP, SSH)

6.6 Outils de détection et de prévention du scanning

Les professionnels de la sécurité utilisent des outils sophistiqués pour détecter les tentatives actives de scanning réseau et de ports :

- **ExtraHop** — <https://www.extrahop.com> : visibilité complète, détection en temps réel et réponse intelligente au scanning réseau malveillant. Découverte et classification automatiques de chaque périphérique (y compris les dispositifs IoT non gérés), analyse en temps réel de toutes les interactions réseau (y compris les transactions cloud et le trafic chiffré SSL/TLS).
- **Splunk Enterprise Security** — <https://www.splunk.com>
- **Scanlogd** — <https://github.com>
- **Vectra Detect** — <https://www.vectra.ai>
- **IBM Security QRadar XDR** — <https://www.ibm.com>
- **Cynet 360 AutoXDR** — <https://www.cynet.com>

Synthèse du module

Ce module a montré : - Comment les attaquants déterminent les hôtes actifs à partir d'une plage d'adresses IP en envoyant diverses requêtes de ping scan à plusieurs hôtes - Comment les attaquants effectuent différentes techniques de scanning pour déterminer les ports ouverts, les services, les versions de services, etc., sur le système cible - Comment les attaquants effectuent le banner grabbing ou le fingerprinting OS pour déterminer l'OS tournant sur un système cible distant - Les techniques de scanning que les attaquants peuvent employer pour contourner les règles IDS/firewall et les mécanismes de journalisation, et se déguiser en trafic réseau normal - Les contre-mesures au scanning réseau pour défendre le réseau contre les attaques de scanning

Le prochain module discutera en détail de la façon dont les attaquants, ainsi que les hackers éthiques et les pentesters, effectuent l'énumération (enumeration) pour collecter des informations sur une cible avant une attaque ou un audit.

Aide-mémoire examen (à retenir absolument)

Concept	Détail clé
6 flags TCP	SYN, ACK, PSH, URG, FIN, RST (1 bit chacun)
Flags du SYN scan	SYN, ACK, RST
3 types de scanning	Port, Network, Vulnerability
ARP ping scan	-PR — le plus efficace/précis ; défaut de Nmap
UDP ping scan	-PU — port par défaut 40125
ICMP timestamp	-PP ; ICMP address mask
TCP SYN ping	-PS — port 80, sans logs ; TCP ACK ping
IP protocol ping	-P0 — ICMP(1), IGMP(2), IP-in-IP(4)
-sn	Désactive le scan de ports (ping scan seul)
--disable-arp-ping	Désactive le ARP ping scan par défaut
TCP Connect	-sT — three-way handshake complet, facile à détecter, pas de privilèges root
Half-open/Stealth	-sS — RST avant fin du handshake, contourne firewall/logs
Inverse flag scan	FIN/URG/PSH/NULL → ouvert = aucune réponse, fermé = RST (UNIX/BSD uniquement, RFC 793)

Concept	Détail clé
Xmas scan	-sX — FIN+URG+PSH
Maimon scan	-sM — sonde FIN/ACK
ACK scan	-sA — TTL < 64 → ouvert ; window non nulle → ouvert ; pas de réponse = firewall stateful
Idle scan	-sI — zombie, IPID ; incrément de 2 → port ouvert
UDP scan	-sU — ICMP port unreachable = fermé ; lent
SCTP INIT	-sY — INIT/INIT-ACK/COOKIE-ECHO/COOKIE-ACK (4-way handshake)
SCTP COOKIE ECHO	-sZ
SSDP	UPnP, port 1900/UDP, Metasploit ssdp_msearch
List scan	-sL — aucun scan réel, 0 hosts up
IPv6 scan	-6 — 2 ⁶⁴ adresses possibles
Version de service	-sV — base service-probes
Détection OS	-O ; NSE smb-os-discovery
TTL Windows	128 ; TTL Linux/Unix
Windows window size	65 535 à 1 Go ; Linux
9 tests Nmap OS	SYN+ECN-Echo, NULL, URG+PSH+SYN+FIN, ACK ouvert, SYN fermé, ACK fermé, URG+PSH+FIN fermé, PU, TSeq
Fingerprinting passif	erreurs, sniffing, extensions (.aspx → IIS/Windows)
Fragmentation	-f — SYN/FIN scanning avec fragments IP
Source routing	loose/strict ; champ IP options
Source port manipulation	-g / --source-port (ex. -g 80)
IP decoy	-D RND:10 ou -D decoy1,decoy2,ME
IP spoofing	Hping3 -a ; pas de handshake complet possible
MAC spoofing	--spoof-mac 0 / [Vendor] / [new MAC]
Custom packets	Colasoft Packet Builder, NetScanTools Pro
Randomize hosts	--randomize-hosts — groupes de 16 384 hôtes
Bad checksums	--badsum
Proxy chaining	plus de proxies = plus d'anonymat
Anonymizers	networked (réseau d'ordinateurs) vs single-point (site web)
Ports à filtrer	135-159, 256-258, 389, 445, 1080, 1745, 3268
ICMP countermeasure	terminer la connexion > 10 requêtes ECHO
Détection spoofing	Direct TTL probes, IPID, TCP flow control
Contre-mesures spoofing	pas de confiance IP, random ISN, ingress/egress filtering, chiffrement IPsec
Outils de détection	ExtraHop, Splunk ES, Scanlogd, Vectra, QRadar, Cynet
Apache banner	ServerSignature off, ServerTokens Prod, mod_headers
IIS banner	Urlscan.ini RemoveServerHeader=1

CEH v13 Dump — Module 03 : Scanning Networks

Exam-Style Practice Questions (312-50) — With Answer Key

60 multiple-choice questions based on Module 03 content. Answer key at the end.

Questions

Part A — Network Scanning Concepts (Q1-Q14)

- Q1. Network scanning** is best defined as: - A) The process of identifying live hosts, ports, and services in a network - B) The process of directly exploiting open ports - C) The process of cracking user passwords - D) The process of installing backdoors on the target
- Q2.** Which type of scanning **lists the active hosts and IP addresses** of a network? - A) Port scanning - B) Network scanning - C) Vulnerability scanning - D) Banner grabbing
- Q3.** Which type of scanning shows the **presence of known weaknesses**? - A) Port scanning - B) Network scanning - C) Vulnerability scanning - D) Host discovery
- Q4.** Which of the following are the **six TCP control flags**? - A) SYN, ACK, PSH, URG, FIN, RST - B) SYN, ACK, PSH, SEQ, FIN, RST - C) SYN, ACK, ECE, CWR, FIN, RST - D) SYN, ACK, PSH, URG, FIN, CWR
- Q5.** According to the module, which TCP flag do **attackers use to scan hosts and identify open ports**? - A) SYN - B) RST - C) URG - D) PSH
- Q6.** The **three-way handshake** between a client and a server proceeds in which order? - A) SYN → SYN+ACK → ACK - B) SYN → ACK → SYN+ACK - C) ACK → SYN → SYN+ACK - D) SYN → RST → ACK
- Q7.** Which statement about the **TCP Connect (full-open) scan** (-sT) is TRUE? - A) It requires super-user privileges - B) It completes the three-way handshake and does NOT require super-user privileges - C) It never completes the three-way handshake - D) It only sends ICMP packets
- Q8.** The **PSH (Push)** flag: - A) Notifies the emission of a new sequence number - B) Orders the system to process data immediately - C) Aborts the connection on error - D) Announces that no more transmission will be sent
- Q9.** In the TCP header, each control flag has a size of: - A) 1 byte - B) 2 bits - C) 1 bit - D) 4 bits
- Q10.** Which TCP flag **announces the end of transmission** (no more data will be sent)? - A) FIN - B) SYN - C) URG - D) RST
- Q11.** The **SYN scanning** technique mainly involves which three flags? - A) SYN, ACK, RST - B) SYN, FIN, RST - C) SYN, ACK, PSH - D) FIN, URG, PSH
- Q12.** Which of the following is NOT a network scanning tool mentioned in the module? - A) Nmap - B) Hping3 - C) BitLocker - D) NetScanTools Pro
- Q13.** In the network scanning process, the attacker: - A) Sends TCP/IP probes, receives network information back, and creates a profile of the target organization - B) Sends TCP/IP probes to directly exploit the target - C) Only performs passive information gathering - D) Skips the reconnaissance phase
- Q14.** Which statement about **open ports** is TRUE? - A) A system with fewer open ports is always more secure than one with more open ports - B) Ports are like doors and windows: the more open ports, the larger the attack surface, but fewer ports do not always mean higher security - C) Open ports have no relation to system vulnerability - D) Only UDP ports can be exploited

Part B — Host Discovery (Q15-Q27)

- Q15.** What is the **first task** in the network scanning process? - A) Port scanning - B) Host discovery - C) OS discovery - D) Vulnerability scanning
- Q16.** Which Nmap host discovery technique is considered the **most efficient and accurate**? - A) ARP ping scan (`-PR`) - B) UDP ping scan (`-PU`) - C) ICMP timestamp ping (`-PP`) - D) IP protocol ping (`-P0`)
- Q17.** By default, the **UDP ping scan** (`-PU`) sends UDP packets to which port? - A) 80 - B) 40125 - C) 53 - D) 443
- Q18.** The **ICMP ECHO ping scan** (`-PE`) sending echo requests to broadcast addresses does NOT work against: - A) Linux machines - B) UNIX machines - C) Windows machines - D) BSD machines
- Q19.** Which ICMP-based host discovery technique **obtains the current time** from the target and is effective when ICMP ECHO is blocked? - A) ICMP timestamp ping (`-PP`) - B) ICMP address mask ping (`-PM`) - C) IP protocol ping (`-P0`) - D) ARP ping scan
- Q20.** The **TCP SYN ping** (`-PS`) sends an empty TCP SYN packet to which default port and with which advantage? - A) Port 53; it creates full connection logs - B) Port 80; no connection is established, so no logs are created - C) Port 443; it establishes full connections - D) Port 25; it creates full connection logs
- Q21.** Why is the **TCP ACK ping** (`-PA`) effective at discovering hosts? - A) Because it completes the three-way handshake - B) Because firewalls usually block SYN packets while the ACK probe easily bypasses such rules - C) Because it sends ICMP ECHO requests - D) Because it uses the DNS protocol
- Q22.** By default, the **IP protocol ping** (`-P0`) probes which protocols? - A) ICMP (1), IGMP (2), and IP-in-IP (4) - B) TCP (6), UDP (17), and SCTP (132) - C) ICMP (1), UDP (17), and TCP (6) - D) ARP only
- Q23.** In Nmap, which option **disables port scanning** (ping scan only)? - A) `-sS` - B) `-sn` - C) `-sU` - D) `-sL`
- Q24.** Why would an attacker use `--disable-arp-ping` ? - A) To enable the ARP ping scan - B) To disable Nmap's default ARP ping scan and perform other ping scans - C) To disable ICMP - D) To randomize the host order
- Q25.** An ICMP ECHO ping sweep packet contains: - A) 64 bytes (56 bytes of data + 8 bytes of protocol header) - B) 32 bytes total - C) 128 bytes (56 bytes of data + 72 bytes of header) - D) 512 bytes
- Q26.** **Angry IP Scanner** is a ping sweep tool that: - A) Creates a separate scan thread for each IP address (multithreaded) - B) Only scans UDP ports - C) Only works on Windows Server - D) Cannot record scan results
- Q27.** Which Hping3 command performs an **ICMP ping** (echo request)? - A) `hping3 -1 10.0.0.25` - B) `hping3 -A 10.0.0.25 -p 80` - C) `hping3 -8 50-60 -S 10.0.0.25 -V` - D) `hping3 -9 HTTP -I eth0`
-

Part C — Port and Service Discovery (Q28-Q42)

- Q28.** The **TCP Connect (full-open) scan** (`-sT`): - A) Completes the three-way handshake then sends an RST to close the connection - B) Never completes the handshake - C) Requires super-user privileges - D) Cannot detect closed ports
- Q29.** The **stealth (half-open) scan** (`-sS`) works by: - A) Sending an RST to the server before the three-way handshake completes - B) Completing the full three-way handshake - C) Sending UDP packets - D) Using the zombie's IP address
- Q30.** In the **inverse TCP flag scan** (FIN/URG/PSH/NULL), an OPEN port responds with: - A) RST - B) RST/ACK - C) No response - D) SYN/ACK
- Q31.** The inverse TCP flag scan technique is only effective against which systems? - A) Microsoft Windows - B) UNIX-based operating systems (RFC 793-compliant BSD stack) - C) Cisco routers - D) Android devices

- Q32.** The **Xmas scan** (`-sX`) sends packets with which flags set? - A) FIN, URG, PUSH - B) SYN, ACK, FIN - C) No flags (NULL) - D) SYN only
- Q33.** The **NULL scan** (`-sN`) sends packets with: - A) All flags set - B) No flags set - C) Only the FIN flag - D) Only the ACK flag
- Q34.** The **Maimon scan** (`-sM`) uses which probe? - A) FIN/ACK - B) SYN - C) URG/PSH/FIN - D) UDP
- Q35.** In the **TTL-based ACK flag probe scan**, a port is considered OPEN when the TTL of the received RST packet is: - A) Greater than 128 - B) Less than 64 - C) Equal to 255 - D) Exactly 128
- Q36.** In the **window-based ACK scan** (`-sW`), a port is considered OPEN when the window value is: - A) Non-zero - B) Zero - C) Negative - D) Always 65535
- Q37.** In the **idle (IPID header) scan** (`-sI`), the zombie's IPID must be incremented by how much to indicate an OPEN port on the target? - A) 1 - B) 2 - C) 0 - D) 64
- Q38.** In the **UDP scan** (`-sU`), a port is considered CLOSED when: - A) No response is received - B) An ICMP port unreachable message is received - C) An RST packet is received - D) A SYN/ACK packet is received
- Q39.** The **SCTP INIT scan** (`-sY`) is based on which handshake? - A) Three-way handshake - B) Four-way handshake (INIT → INIT-ACK → COOKIE-ECHO → COOKIE-ACK) - C) Two-way handshake - D) No handshake
- Q40.** The **List scan** (`-sL`) is characterized by: - A) Generating and printing a list of IPs/hostnames without actually scanning them (0 hosts up) - B) Scanning all ports of the target - C) Sending ICMP ECHO to all hosts - D) Detecting the OS of hosts
- Q41.** **Service version discovery** (`-sV`) works by using: - A) The `service-probes` database of Nmap - B) The ARP cache - C) The DNS zone file - D) The TTL value only
- Q42.** Which statement about **IPv6 scanning** (`-6`) is TRUE? - A) The IPv6 address space is 64 bits - B) There are 2^{64} possible addresses per subnet, making classic scanning infeasible - C) IPv6 scanning uses the same address space as IPv4 - D) IPv6 addresses can be easily brute-forced
-

Part D — OS Discovery, IDS/Firewall Evasion and Countermeasures (Q43-Q60)

- Q43.** **Active banner grabbing** (OS fingerprinting) is best described as: - A) Sending specially designed packets to the remote OS and comparing the responses against a database to determine the OS - B) Sniffing traffic to determine the OS - C) Reading the target's log files - D) Asking the administrator for OS details
- Q44.** A **TTL value of 128** in the first packet of a TCP session most likely indicates: - A) Linux - B) Windows - C) Solaris - D) Cisco router
- Q45.** A **TTL value of 255** most likely indicates: - A) Windows - B) Linux - C) OpenBSD, Cisco routers, Solaris, or AIX - D) FreeBSD always
- Q46.** Which OS is associated with a **TCP window size of 5840**? - A) Windows - B) Linux - C) FreeBSD - D) Solaris
- Q47.** In **passive fingerprinting**, a page extension of `.aspx` most likely indicates: - A) An Apache server on Linux - B) An IIS server on Windows - C) An nginx server on FreeBSD - D) A Tomcat server on Solaris
- Q48.** Nmap **OS detection** (`-O`) uses how many tests to determine the OS fingerprint? - A) 5 - B) 9 - C) 18 - D) 12
- Q49.** Which Nmap Script Engine (NSE) script collects OS information from the target via the **SMB protocol**? - A) `smb-os-discovery` - B) `http-enum` - C) `dns-zone-transfer` - D) `ssh2-enum-algos`
- Q50.** **Packet fragmentation** as an IDS/firewall evasion technique (`-f`) works because: - A) IDS/firewalls process fragments one by one and most are configured to skip fragmented packets during port scans - B) Fragments are encrypted - C) IDS cannot reassemble fragments - D) Fragments use a different protocol

- Q51.** Which Nmap option lets the attacker set the source port to a **well-known port** (e.g., HTTP port 80) to bypass IDS/firewall rules? - A) `-g 80` - B) `-f` - C) `-D RND:10` - D) `--badsum`
- Q52.** The **IP address decoy** technique (`-D RND:10`) makes it appear that: - A) The decoys and the real host are all scanning the network - B) Only the real host is scanning - C) The target is scanning the attacker - D) No scanning is taking place
- Q53.** Why can an attacker NOT open a successful TCP connection using **IP address spoofing**? - A) Because the three-way handshake cannot be completed (the SYN/ACK goes to the spoofed address) - B) Because spoofed packets are always dropped - C) Because TCP requires HTTPS - D) Because the firewall blocks all spoofed traffic
- Q54.** In Nmap, `--spoof-mac 0` : - A) Generates a completely random MAC address - B) Uses the Dell vendor MAC address - C) Uses the MAC address 00:01:02:25:56:AE - D) Disables MAC spoofing
- Q55.** The `--badsum` option allows an attacker to: - A) Send packets with invalid TCP/UDP checksums to evade certain firewall rules - B) Create valid checksums for all packets - C) Randomize the host order - D) Fragment packets into smaller pieces
- Q56. Proxy chaining** provides greater anonymity because: - A) Each proxy removes the user's identifying information before passing the request to the next proxy - B) Proxies encrypt the final destination - C) Proxies always use HTTPS - D) The target cannot see any traffic
- Q57.** Which type of anonymizer transfers information through a **network of computers** connected to the Internet before passing it to the target website? - A) Single-point anonymizer - B) Networked anonymizer - C) Proxy server - D) NAT gateway
- Q58.** Which is an effective **countermeasure against ping sweep attacks**? - A) Terminating the connection with any host sending more than 10 ICMP ECHO requests - B) Allowing all ICMP ECHO traffic - C) Disabling the IDS - D) Using public IP addresses for internal devices
- Q59.** According to the module, which set of ports should be **filtered** to secure a network? - A) 135-159, 256-258, 389, 445, 1080, 1745, 3268 - B) 80, 443, 53, 22 - C) 1-100 only - D) 8000, 8080, 8888
- Q60.** To prevent the disclosure of the **server version** in the Apache banner, which directive should be set in `httpd.conf` ? - A) `ServerTokens Prod` - B) `ServerTokens Full` - C) `ServerSignature on` - D) `RemoveServerHeader 1`

Answer Key

Part A

Q	Answer	Explanation
1	A	Network scanning identifies live hosts, ports, and services in a network
2	B	Network scanning = listing active hosts and IP addresses
3	C	Vulnerability scanning reveals the presence of known weaknesses
4	A	The 6 TCP flags: SYN, ACK, PSH, URG, FIN, RST (1 bit each)
5	B	RST is set to 1 to abort a connection on error; attackers use it to scan hosts and identify open ports
6	A	SYN → SYN+ACK → ACK establishes a TCP session
7	B	TCP Connect scan completes the handshake and does NOT need super-user privileges; it is easily detectable
8	B	PSH orders the receiver to process data immediately
9	C	Each TCP control flag is 1 bit (TCP Flags section = 6 bits)

Q	Answer	Explanation
10	A	FIN announces that no more transmission will be sent (ends the connection)
11	A	SYN scanning mainly involves the SYN, ACK, and RST flags
12	C	BitLocker is Windows disk encryption, not a scanning tool (Nmap, Hping3, Metasploit, NetScanTools Pro are)
13	A	Attacker sends TCP/IP probes → network returns information → attacker creates a profile of the target
14	B	More open ports = more attack surface, but fewer ports do not always mean higher security

Part B

Q	Answer	Explanation
15	B	Host discovery is the first task of the network scanning process
16	A	ARP ping scan (-PR) is the most efficient and accurate; it is Nmap's default on IPv4 local networks
17	B	UDP ping scan sends UDP packets to port 40125 by default
18	C	ICMP ECHO to broadcast addresses works on UNIX/Linux/BSD but NOT on Windows
19	A	ICMP timestamp ping (-PP) gets the current time and works when ECHO is blocked
20	B	TCP SYN ping uses port 80; no connection is established so no logs are created
21	B	Firewalls usually block SYN; the ACK probe bypasses such rules (target replies with RST)
22	A	IP protocol ping default probes ICMP (1), IGMP (2), and IP-in-IP (4)
23	B	-sn disables port scanning (ping scan only)
24	B	--disable-arp-ping turns off the default ARP ping scan to use other ping scans
25	A	A ping packet = 64 bytes (56 data + 8 protocol header)
26	A	Angry IP Scanner is multithreaded: one scan thread per IP address
27	A	hping3 -1 = ICMP ping; -A = ACK scan; -8 = scan mode; -9 = listen mode

Part C

Q	Answer	Explanation
28	A	TCP Connect completes the handshake (SYN→SYN+ACK→ACK) then sends RST to close
29	A	Stealth scan sends RST before the handshake completes (half-open connection)
30	C	In inverse flag scans an open port gives NO response; a closed port replies RST/ACK
31	B	Only RFC 793-compliant (UNIX/BSD) stacks respond correctly; Windows ignores RFC 793
32	A	Xmas scan = FIN + URG + PUSH flags
33	B	NULL scan = no flags set
34	A	Maimon scan uses the FIN/ACK probe
35	B	TTL of the RST < 64 → port open; TTL ≥ 64 → closed
36	A	Non-zero window → open; zero window → closed
37	B	IPID increment of 2 → open port (the target sent a SYN/ACK to the zombie which answered RST); 1 → closed
38	B	ICMP port unreachable → closed; no response → open or filtered

Q	Answer	Explanation
39	B	SCTP uses a four-way handshake: INIT → INIT-ACK → COOKIE-ECHO → COOKIE-ACK
40	A	List scan only prints a list of targets without scanning (0 hosts up)
41	A	<code>-sV</code> uses the <code>service-probes</code> database of Nmap
42	B	IPv6 = 128 bits, 64-bit host space (2^{64} addresses per subnet); classic scanning is infeasible

Part D

Q	Answer	Explanation
43	A	Active banner grabbing sends designed packets and compares responses with a database
44	B	TTL 128 → Windows; TTL 64 → Linux/Unix; TTL 255 → OpenBSD/Cisco/Solaris/AIX
45	C	TTL 255 → OpenBSD, Cisco routers, Solaris, or AIX
46	B	Linux window size = 5840; FreeBSD = 65535; Solaris = 8760; OpenBSD/AIX = 16384
47	B	<code>.aspx</code> extension → IIS server on Windows
48	B	Nmap OS detection uses 9 tests (SYN+ECN-Echo, NULL, URG+PSH+SYN+FIN, ACK, etc. + PU + TSeq)
49	A	<code>smb-os-discovery</code> collects OS info via SMB
50	A	IDS/firewalls process fragments one by one and often skip fragmented packets during port scans
51	A	<code>-g</code> / <code>--source-port</code> sets the source port (e.g., <code>-g 80</code>)
52	A	Decoys make it appear that many hosts (decoys + real IP) are scanning the target
53	A	Spoofed SYN → the SYN/ACK goes to the spoofed address, so the handshake cannot complete
54	A	<code>--spoof-mac 0</code> = random MAC; <code>[Vendor]</code> = vendor MAC; <code>[new MAC]</code> = manual MAC
55	A	<code>--badsum</code> sends invalid TCP/UDP checksums to evade firewall rules that skip checksum checks
56	A	Each proxy in the chain removes identifying info before forwarding the request
57	B	Networked anonymizers use a network of computers; single-point anonymizers use a single website
58	A	Terminating connections sending >10 ICMP ECHO requests is a ping sweep countermeasure
59	A	Filter ports: 135-159, 256-258, 389, 445, 1080, 1745, 3268
60	A	ServerTokens Prod in Apache; IIS uses <code>RemoveServerHeader=1</code> in Urlscan.ini

Indicative scoring

- **50-60 correct:** excellent — ready for the exam
- **40-49:** good — review the missed sections
- **30-39:** average — restudy the course, then retry
- **< 30:** re-read the complete Module 03 course document

Dump generated from the content of CEH v13 Module 03 (Scanning Networks). In case of OCR transcription errors, the official EC-Council PDF remains the reference.